Applied Research MSc Thesis Proposal

By

EL HAYEK Roy

MSc 2 Artificial Intelligence

July 2026

Proposed Title

LLM-Based Autonomous SOC Agent for IoT Cyberattack Detection and Response

Research Gap

Large Language Models (LLMs) and autonomous AI agents are increasingly applied to Security Operations Center (SOC) tasks such as log summarization, alert triage, threat intelligence, and incident response [1], [4]. This work builds on agent architectures that combine reasoning with tool use [10]–[12]. Autonomous cyber-defense agents have already been designed and evaluated, but only for enterprise networks [2], [3].

In parallel, intrusion detection for the Internet of Things (IoT) is a mature field of its own. Traditional techniques transfer poorly to resource-constrained devices and IoT-specific protocols [5]. In response, the community has produced ground-truth benchmark datasets, including Bot-IoT [6], TON_IoT [7], CICIoT2023 [8], and the MQTT-specific MQTTset [9], as well as lightweight transformer-based classifiers for IoT threat detection [17].

Recent studies have begun to connect the two fields:

- IDS-Agent, the first LLM agent for IoT intrusion detection, reasons over classifier outputs and retrieved knowledge to produce explained benign or malicious verdicts on benchmark traffic [16];
- the framework of Chou et al. pairs ensemble detection with a ReAct-based retrieval-augmented agent that generates evidence-grounded incident reports on the ACI-IoT-2023 dataset [18];
- CyberRAG, an agentic RAG framework, uses a central LLM agent to orchestrate specialized classifiers and a retrieve-and-reason loop, delivering real-time classification, explanation, and structured reporting for enterprise IDS/IPS alerts [19].

These systems narrow the gap but do not close it. They stop at detection [16], [17], at report generation [18], [19], or at classification and reporting for enterprise alerts rather than IoT [19]. None of them fuses multiple live telemetry sources, none enforces explicit safety constraints on its recommendations, and none is evaluated end to end against ground truth generated in a controlled testbed. The evidence shows these matters. Even the safest tool-using agents fail at measurable rates [13], risk awareness in agent behavior remains an open problem [14], and risk-management frameworks call for controlled autonomy in high-stakes settings [15].

To the best of our knowledge, no published work combines heterogeneous IoT security telemetry (MQTT anomalies, network flows, and honeypot logs), agentic incident classification, and safety-constrained structured response recommendation in a single autonomous SOC agent evaluated end to end against ground truth.

This is the scientific gap this thesis seeks to address.

Central Research Question

Does an LLM-based autonomous SOC agent significantly improve incident detection, classification accuracy, and response safety in IoT environments compared to non-agentic approaches?

Research Problem (Scientific Formulation)

Conventional intrusion detection systems for IoT, whether rule-based or machine-learning-based, can detect anomalous activity with high accuracy on benchmark data [5]–[8]. However, their output is only a stream of low-level alerts. These systems do not interpret alerts, do not correlate evidence from several sources, and do not recommend responses. Even recent LLM-assisted systems stop at classification [16], [17] or at report generation [18], [19]. The work of interpretation and decision therefore still falls on human analysts, who are already overloaded [1].

Large Language Models offer the missing capabilities. They can reason over unstructured data and, in agentic form, use tools across several steps [10]–[12]. However, LLMs are probabilistic. Tool-using agents fail at measurable rates even in normal conditions [13], and they often do not recognize the risks of their own actions [14]. In a security context, this is a serious problem. A wrong or excessive recommendation, such as isolating a critical device because of a false alarm, can cause as much harm as the attack itself. LLM agents in this role therefore need controlled autonomy: a limited action space, output validation, and full auditability [15]. The agent must assist and recommend, not execute.

The problem lies at the intersection of three fields. IoT intrusion detection provides detection but no interpretation or response. LLM-based autonomous agents provide reasoning and tool use but limited reliability. AI risk management provides constraint mechanisms that have rarely been applied to security response generation. How can we design an LLM-based SOC agent that combines heterogeneous IoT telemetry, classifies incidents accurately, and generates structured response recommendations under explicit safety constraints, and how does it perform against ground truth compared to non-agentic alternatives?

Research Questions

Research Question 1

Does combining several telemetry sources (MQTT anomalies, network flows, honeypot logs) improve incident detection and classification compared to using a single source?

Research Question 2

Does the agentic workflow (step-by-step reasoning, tool use, knowledge retrieval) classify incidents more accurately than a prompt-only LLM using the same base model?

Research Question 3

Do explicit safety constraints (a limited action list, structured output format, and validation rules) reduce unsafe or invalid recommendations without making the recommendations less useful?

Research Question 4

Does the complete agent perform significantly better than two non-agentic baselines, a conventional machine-learning classifier and a prompt-only LLM, in detection, classification, and response safety, when evaluated against ground truth?

Hypotheses

Below are the **scientific propositions** that the experiments are intended to confirm or falsify.

H1 - Multi-Source Correlation

Combining MQTT anomalies, network flows, and honeypot logs will give significantly higher detection and classification performance than any single source alone.

H2 - Agentic Classification

The agentic workflow will classify incident type and severity significantly more accurately than a prompt-only LLM built on the same base model.

H3 - Constraint Effectiveness

Explicit safety constraints will significantly reduce unsafe or invalid recommendations compared to the same agent without constraints, with no significant loss in usefulness.

H4 - End-to-End Superiority

The complete agent will significantly outperform both non-agentic baselines on detection and classification, while producing significantly fewer unsafe recommendations.

Research Objectives

The main objective of this research is to design and evaluate an LLM-based autonomous SOC agent that analyzes IoT security telemetry, classifies incidents, and generates safe, structured response recommendations. This breaks down into five specific objectives.

1. Build a small IoT cybersecurity testbed that produces both normal and malicious activity and collect three types of telemetry from it: MQTT anomalies, network flows, and honeypot logs.
2. Design an LLM-based agent workflow that reads these alerts, correlates evidence across the three sources, and classifies each incident by type, severity, and affected device.

3. Implement safety constraints on the agent, namely a limited action space, structured output schemas, and validation rules, so that it recommends actions in a controlled and auditable way and never executes them.
4. Define a ground-truth reference for the testbed scenarios and a scoring protocol for both classification accuracy and the safety and usefulness of recommendations.
5. Evaluate the agent against this ground truth and against two non-agentic baselines (a machine-learning classifier and a prompt-only LLM), measuring detection, classification, response safety, and reliability.

Methodology

This research uses an experimental and quantitative approach. The system is built, then measured against ground truth and against non-agentic baselines, so that each research question is answered with numerical evidence. This comparative, hypothesis-driven design matches the sample proposal and suits the work, because detection, classification, and response safety can all be measured and compared.

A small, isolated IoT testbed generates the data. It contains IoT devices or emulators communicating over MQTT, a network segment where traffic is captured, and a decoy (honeypot) host, producing three telemetry sources: MQTT anomalies, network flows, and honeypot logs. The devices, protocols, and attacks are guided by established IoT security datasets, namely Bot-IoT [6], TON_IoT [7], CICIoT2023 [8], and MQTTset [9], so the setup is realistic and reproducible. The testbed is run under normal and malicious activity, with attacks such as denial-of-service, scanning, brute-force login attempts, and botnet traffic drawn from those datasets. Because every attack is executed deliberately, the correct label of each event is known in advance and forms the ground truth. Detectors on the testbed, rule-based or machine-learning-based, convert this telemetry into the alerts the agent consumes.

The core of the system is an LLM-based agent that follows a reason-and-act loop [10] and uses external tools such as log parsers, detectors, an MQTT monitor, and a retrieval component [11]. Given a set of alerts, the agent correlates evidence across the three telemetry sources, classifies the incident by type, severity, and affected device, and produces a structured response recommendation. This design draws on IDS-Agent [16] and CyberRAG [19]. The agent operates under explicit safety constraints so that it recommends actions in a controlled and auditable way and never executes them: a limited action space of permitted recommendations, a structured output schema (incident type, severity, affected device, evidence, recommended action), validation rules that reject unsafe or malformed output, and an audit log of every decision. This layer responds to evidence that even the safest tool-using agents fail at measurable rates [13], that agents often miss the risks of their own actions [14], and that high-stakes autonomy must be controlled [15].

The agent is compared against two non-agentic baselines: a conventional machine-learning classifier trained on the same telemetry, and a prompt-only LLM that receives the same alerts

but has no agentic workflow, tools, or safety layer. The prompt-only baseline uses the same base language model as the agent, so any difference reflects the architecture rather than the model. The experiments follow the four hypotheses. For H1, the agent runs on each single source and on all three combined. For H2, the agent is compared against the prompt-only LLM. For H3, the agent runs once with the safety layer on and once with it off, isolating the effect of the constraints. For H4, the complete agent is compared against both baselines. All conditions use the same scenarios, so the comparisons are paired and analyzed with paired statistical tests.

Detection is measured with precision, recall, and F1; classification with accuracy and macro-averaged F1; response safety as the proportion of unsafe or invalid recommendations; and usefulness as agreement with a predefined set of acceptable actions. To score recommendations consistently, a set of acceptable actions and a set of unsafe actions are fixed for each scenario before any experiment is run and kept the same across all conditions. All attacks are carried out only on the isolated testbed, which is not connected to any production or third-party network; no human subjects or personal data are involved, and any use of AI tools is acknowledged transparently in line with the dissertation guide.

Expected Outcomes

This research is expected to produce a working LLM-based SOC agent for IoT environments that reads security alerts from three telemetry sources, classifies each incident by type, severity, and affected device, and generates a structured response recommendation under explicit safety constraints. Alongside the agent, the work will deliver the small IoT testbed used to generate the evaluation data, together with the labelled normal and malicious scenarios that serve as ground truth.

The evaluation is expected to show, with measurable evidence, whether combining several telemetry sources improves detection and classification over a single source, whether the agentic workflow classifies incidents more accurately than a prompt-only LLM, whether the safety constraints reduce unsafe or invalid recommendations without lowering their usefulness, and how the complete agent compares against non-agentic baselines. Whatever the direction of these results, the study will report them honestly, including any case where the agent does not outperform a baseline, since a clear negative result is still a useful contribution.

The main contribution is a controlled, auditable LLM-based SOC assistant that does not stop at detection or reporting, but goes as far as safe, structured response recommendation, and that is evaluated end to end against ground truth in an IoT setting. The results are also expected to show where such an agent is reliable and where it is not, which is useful for future work on controlled autonomy in security operations.

References

[1] S. Srinivas et al., "AI-augmented SOC: A survey of LLMs and agents for security automation," J. Cybersecur. Privacy, vol. 5, no. 4, art. 95, 2025, doi: 10.3390/jcp5040095.

[2] J. Loevenich, E. Adler, T. Hürten, and R. R. F. Lopes, “Design and evaluation of an autonomous cyber defence agent using DRL and an augmented LLM,” Comput. Netw., vol. 262, art. 111162, 2025, doi: 10.1016/j.comnet.2025.111162.

[3] T. Radah, H. Chaoui, and C. Saadi, “ReAct-driven SOC agent with integrated detection engineering for AI-enhanced autonomous alert handling,” J. Inf. Syst. Eng. Manage., vol. 10, no. 53s, pp. 730–746, 2025, doi: 10.52783/jisem.v10i53s.10967.

[4] H. Alqahtani et al., “Secure autonomous cyber defense with LLM agents: A systematic review of autonomy, tool-augmented reasoning, and governance constraints,” Comput. Electr. Eng., 2026. [Complete author list, volume, and article number to be confirmed from the ScienceDirect record.]

[5] B. B. Zarpelão, R. S. Miani, C. T. Kawakani, and S. C. de Alvarenga, “A survey of intrusion detection in Internet of Things,” J. Netw. Comput. Appl., vol. 84, pp. 25–37, 2017, doi: 10.1016/j.jnca.2017.02.009.

[6] N. Koroniotis, N. Moustafa, E. Sitnikova, and B. Turnbull, “Towards the development of realistic botnet dataset in the Internet of Things for network forensic analytics: Bot-IoT dataset,” Future Gener. Comput. Syst., vol. 100, pp. 779–796, 2019, doi: 10.1016/j.future.2019.05.041.

[7] A. Alsaedi, N. Moustafa, Z. Tari, A. Mahmood, and A. Anwar, “TON_IoT telemetry dataset: A new generation dataset of IoT and IIoT for data-driven intrusion detection systems,” IEEE Access, vol. 8, pp. 165130–165150, 2020, doi: 10.1109/ACCESS.2020.3022862.

[8] E. C. P. Neto, S. Dadkhah, R. Ferreira, A. Zohourian, R. Lu, and A. A. Ghorbani, “CICIoT2023: A real-time dataset and benchmark for large-scale attacks in IoT environment,” Sensors, vol. 23, no. 13, art. 5941, 2023, doi: 10.3390/s23135941.

[9] I. Vaccari, G. Chiola, M. Aiello, M. Mongelli, and E. Cambiaso, “MQTTset, a new dataset for machine learning techniques on MQTT,” Sensors, vol. 20, no. 22, art. 6578, 2020, doi: 10.3390/s20226578.

[10] S. Yao et al., “ReAct: Synergizing reasoning and acting in language models,” in Proc. Int. Conf. Learn. Represent. (ICLR), 2023.

[11] T. Schick et al., “Toolformer: Language models can teach themselves to use tools,” in Adv. Neural Inf. Process. Syst. (NeurIPS), vol. 36, 2023.

[12] L. Wang et al., “A survey on large language model based autonomous agents,” Front. Comput. Sci., vol. 18, no. 6, art. 186345, 2024, doi: 10.1007/s11704-024-40231-1.

[13] Y. Ruan et al., “Identifying the risks of LM agents with an LM-emulated sandbox,” in

Proc. Int. Conf. Learn. Represent. (ICLR), 2024.

[14] T. Yuan et al., “R-Judge: Benchmarking safety risk awareness for LLM agents,” in Findings Assoc. Comput. Linguistics: EMNLP 2024, pp. 1467–1490.

[15] E. Tabassi, Artificial Intelligence Risk Management Framework (AI RMF 1.0), NIST AI 100-1, 2023, doi: 10.6028/NIST.AI.100-1.

[16] Y. Li, Z. Xiang, N. D. Bastian, D. Song, and B. Li, “IDS-Agent: An LLM agent for explainable intrusion detection in IoT networks,” in NeurIPS 2024 Workshop on Open-World Agents, 2024.

[17] M. A. Ferrag et al., “Revolutionizing cyber threat detection with large language models: A privacy-preserving BERT-based lightweight model for IoT/IIoT devices,” IEEE Access, vol. 12, 2024, doi: 10.1109/ACCESS.2024.3363469. [End page to be confirmed from IEEE Xplore.]

[18] C.-H. Chou, A. Sudheer, and Y. Park, “An LLM-based agentic network traffic incident-report approach towards explainable-AI network defense,” J. Sens. Actuator Netw., vol. 15, no. 2, art. 32, 2026, doi: 10.3390/jsan15020032.

[19] F. Blefari, C. Cosentino, F. A. Pironti, A. Furfaro, and F. Marozzo, “CyberRAG: An agentic RAG cyber attack classification and reporting tool,” Future Gener. Comput. Syst., vol. 176, art. 108186, 2026, doi: 10.1016/j.future.2025.108186.